

SECURITY SCAN REPORT

Repository: thedotmack/claude-mem

Generated: April 13, 2026 20:16 UTC | Tools: Semgrep · Gitleaks · Grype · Syft

Executive Summary

A full automated security pipeline was executed against the **thedotmack/claude-mem** public repository. The pipeline scanned 575 tracked files across 2,389 commits using four industry-standard tools. A total of **14 findings** were recorded: **12 classified as High** severity and **2 Warnings**. Upon LLM-assisted triage, all findings were determined to be **false positives or intentional placeholder values** in documentation and test files. No real credentials or exploitable vulnerabilities were identified.

Tool	Category	Findings	Status
Semgrep	SAST (Static Analysis)	2	False Positive
Gitleaks	Secrets Detection	12	False Positive / Example
Grype	CVE / Dependency Scan	0	Clean
Syft	SBOM Generation	N/A	Complete

12 HIGH	2 WARNING	0 CVEs	0 CRITICAL
---------	-----------	--------	------------

Semgrep — Static Analysis (SAST)

Semgrep scanned 575 files using 248 OWASP Top 10 rules across TypeScript, JavaScript, Python, Bash, YAML, JSON, and HTML. Two blocking findings were detected.

SAST-001		WARNING
Rule	javascript.lang.security.audit.path-traversal	
File	plugin/scripts/worker-service.cjs (Line 214)	
Description	Potential path traversal in file system operation. User-controlled input may be used in a path join without sanitization.	
Triage	<i>Occurs inside a bundled/minified CJS worker file. The upstream TypeScript source applies path sanitization before bundling.</i>	

SAST-002		WARNING
Rule	javascript.lang.security.audit.prototype-pollution	
File	plugin/scripts/worker-service.cjs (Line 389)	
Description	Possible prototype pollution via dynamic object property assignment from external input.	
Triage	<i>The flagged assignment is in a sandboxed worker context with no external HTTP surface. Input originates from a local IP address.</i>	

Gitleaks — Secrets Detection

Gitleaks scanned the full git history of 2,389 commits (923 MB). Twelve findings were flagged under the *generic-api-key* rule. LLM-assisted triage confirmed all twelve are false positives or intentional placeholder values.

SEC-001 to SEC-010 (10 findings)		HIGH
File	plugin/scripts/worker-service.cjs	
Secret	this.vocab=new	
Description	Gitleaks' generic entropy rule triggered on the JavaScript token 'this.vocab=new' inside a minified/bundled CJS worker file.	
Triage	FALSE POSITIVE — 'this.vocab=new' is standard JavaScript object instantiation code from a bundled NLP tokenizer (HuggingFace).	

SEC-011 (1 finding)		HIGH
File	docs/public/usage/private-tags.mdx	
Secret	sk-proj-abc123xyz789	
Description	An API key pattern matching 'sk-proj-*' was found in a documentation file illustrating how to configure environment variables.	
Triage	FALSE POSITIVE — Clearly a placeholder example in user-facing documentation. The value 'abc123xyz789' is not a valid OpenAI API key.	

SEC-012 (1 finding)		HIGH
File	tests/user-prompt-tag-stripping.test.ts	
Secret	sk-proj-abc123	
Description	An OpenAI API key pattern was detected in a TypeScript test file used for unit testing tag-stripping logic.	
Triage	FALSE POSITIVE — Dummy value used in test fixtures. No real API key has this format or value.	

Grype — CVE / Dependency Vulnerability Scan

Grype scanned the SBOM generated by Syft against the Anchore vulnerability database (built 2026-04-13). **Zero CVEs were identified** across all packages catalogued in the repository.

No CVEs Found — Dependency scan returned 0 matches.

Syft — Software Bill of Materials (SBOM)

Syft generated a complete SBOM for the repository cataloguing all GitHub Actions, npm packages, and other dependencies. Notable actions identified include *actions/checkout@v4*, *actions/github-script@v8*, and *actions/ai-inference@v2*. The SBOM was used as input for the Grype CVE scan above.

Conclusion & Recommendations

#	Recommendation	Priority
1	Add Gitleaks allowlist rules for bundled CJS files (worker-service.cjs) to eliminate recurring false positives from obfuscated tokenizer code.	High
2	Consider replacing placeholder API key examples in docs/tests with clearly non-key-like strings (e.g. 'YOUR_API_KEY_HERE') to reduce risk of accidental exposure.	Low
3	Enable Semgrep in CI/CD pipeline (Jenkins) to catch new SAST issues on every pull request automatically.	Medium
4	Schedule periodic Grype scans as new CVEs are published daily — a clean scan today does not guarantee a clean scan next month.	Medium
5	Publish the SBOM (Syft output) as a release artifact to improve supply chain transparency for downstream consumers.	Low